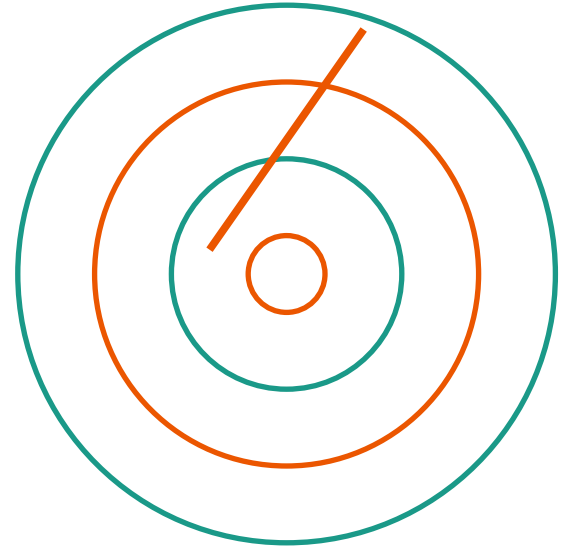


Assessment Tools: Scanning & Interception



Session 9 of 12 - Cybersecurity





S9 Assessment Tools: Scanning & Interception



From method to evidence: gathering what your SRS needs

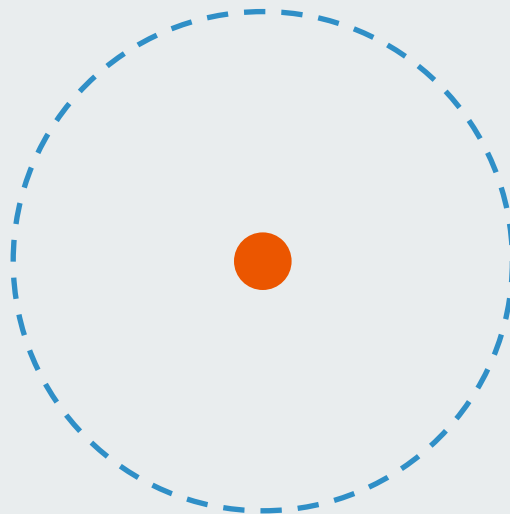
Session Overview



Tools that gather evidence for the security apparatus you started designing in S8

By the end of this session you will be able to:

- Explain what Nmap, ZAP, and Burp Community each find - and, just as important, what each misses
- Interpret real scan output without running an active scan yourself
- Turn raw tool output into a classified, scored, contextualised, documented finding
- Work inside the safety boundary: real tools, safe modes, provided artefacts only



Nmap - ZAP - Burp

Built On S1-S8 - What S9 Adds

Already yours (reused, not re-taught)

- OWASP Top 10 categories - S6
- CVSS as a score you read, and the professional finding format - S8
- NET-01 / NET-02 network SRS requirements - S7
- Attack surface - S2 (Nmap makes it visible today)
- Audit is not a pentest - S8

New in this session

- The dynamic tool landscape: Nmap, OWASP ZAP, Burp Suite Community
- What each tool finds - and, deliberately, what each one misses
- The pipeline: raw output -> classified, scored, contextualised, documented finding
- Dynamic evidence-gathering for Part B (B3, B4) begins today

S8 gave you the method. S9 and S10 give you the tools that gather evidence for it - today: dynamic tools; next session: static and configuration review.

Today's Ground Rules



Evaluation, not exploitation

You are gathering evidence for a security evaluation, exactly as S8 defined it - not attempting a penetration test. Every tool today is used in its safest, evidence-gathering mode.

Provided artefacts only

The Activity interprets a provided Nmap output file. The Lab runs a ZAP PASSIVE scan against a provided demo application. No active scanning, and no scanning of real or third-party systems - ever.

Tool output is not a finding

Raw output must be classified, scored, contextualised, and documented before it belongs in a report. Today you learn the pipeline that does that - not just the tools.

Nmap: Mapping the Attack Surface



- **Network reconnaissance tool** - Network layer
- Discovers open ports on a target host
- Identifies which services are running behind those ports
- Fingerprints the operating system version
- This is what "attack surface" (S2) looks like as data, not just a concept

Analogy

Nmap is like walking around a building checking every door and window. It tells you which ones are unlocked and what room is behind each - it does not tell you what is happening inside those rooms.

Nmap: What It Cannot Tell You



- **Application logic flaws** - Nmap has no concept of what an application does with a request
- **Authentication weaknesses** - a port being open says nothing about how well it is protected
- **Misconfigured permissions** - out of scope entirely; this is not what Nmap inspects
- An open port is a fact. Whether it is a risk depends on what is listening and how it is configured

Coursework hook: Nmap results feed evidence toward NET-01 and NET-02 - but only Nmap. On their own, open ports are not yet a finding; they are the starting point for further investigation (the Activity, next).

OWASP ZAP: Automated Web Scanning



- **Automated web application scanner** - Application layer
- Discovers known vulnerability patterns, missing security headers, injection points
- **Fast:** can sweep an entire application in minutes
- **Noisy:** high false-positive rate - not every flagged item is a real problem

Analogy

ZAP is like an airport metal detector. It scans everyone quickly and flags anything shaped like a known threat pattern - but it cannot tell whether the person carrying it actually intends harm.

ZAP: What Automation Cannot See



- **Business logic flaws** - ZAP has no concept of what the application is supposed to do
- **Context-dependent access control failures** - it cannot tell if you should be allowed to see this data
- Anything requiring authenticated understanding of the application - ZAP does not know your role or intent

Coursework hook: ZAP findings feed APP-01 evidence for Part B (B4) - after classification, scoring, and contextualisation. This is the direct evidence source for today's Small Lab.

Burp Suite Community: Manual Interception

- **Manual interception proxy** - both Application and Network layers
- Intercepts and modifies HTTP/S traffic between browser and server, request by request
- **Slower than automated scanning** - there is no shortcut around reading each request
- Finds what automated tools miss, because the evaluator brings understanding of what the application is meant to do

Analogy

Burp is like sitting with a translator who understands the whole conversation, not just a keyword-spotter. It catches meaning and intent, not only recognisable patterns.

Burp Alone Is Not Enough Either



- **Manual review does not scale** - you cannot manually inspect every request across a large application in the time available
- **It still depends entirely on the evaluator understanding the system** - a Burp session is only as good as the question the evaluator brings to it
- **The real answer is combination**: Nmap for surface, ZAP for breadth, Burp for depth where it matters most

Coursework hook: Burp evidence strengthens both B3 (network/platform) and B4 (application security) findings where automated output alone would be too shallow to defend at viva.

Tool Landscape at a Glance

3

TOOLS TODAY

Nmap - ZAP - Burp

2

LAYERS COVERED

Application + Network

4

PIPELINE STAGES

Classify-Score-Context-Doc

Tool	Layer	Speed	False-Positive Rate	Best For
Nmap	Network	Fast	Low - reports facts, not judgements	Mapping the attack surface
OWASP ZAP	Application	Fast	High - many flags need triage	Breadth, known vulnerability patterns
Burp Community	Application + Network	Slow (manual)	N/A - evaluator-driven, not pattern-driven	Depth, business-logic context

KEY CONCEPT



Tool Output Is Evidence, Not a Verdict

Automated scanners find what matches known PATTERNS. They do not understand business logic. A scan of a banking app will not catch a flaw that lets a user transfer funds out of an account they do not own - the scanner has no concept of account ownership. Tool output must be interpreted by an evaluator, never pasted straight into a report.



Worked Example: The Flaw No Scanner Flags



The scenario

A banking app lets any authenticated user transfer funds by submitting an account ID - it never checks whether that ID belongs to them.

What ZAP sees

Nothing wrong. The request is well-formed and matches no known attack pattern - there is no signature for "the wrong person is allowed to do this."

What a human evaluator sees

Someone who understands account ownership submits an ID that is not theirs - and it succeeds. This is Broken Object Level Authorisation (API-01), the API form of the IDOR from S5, formalised as OWASP A01 in S6.

Raw Output to Professional Finding



- **CLASSIFY** - which OWASP category? (S6)
- **SCORE** - read the CVSS score (S8)
- **CONTEXTUALISE** - the real risk in YOUR assigned-domain system
- **DOCUMENT** - title, severity, evidence, property, SRS mapping, remediation (S8 format)
- A raw scan line is not a finding - a finding is what comes out the far end of this pipeline.

Analogy

Think of raw tool output like a lab blood-test printout. A doctor does not hand you the raw numbers as a diagnosis - they classify what is abnormal, weigh severity, contextualise it against your health history, and document a clinical finding.

Pipeline in Action: One Line to One Finding



Raw ZAP alert: "Missing Anti-CSRF Tokens - /transfer endpoint"

- **Classify:** Maps to OWASP A01 (Broken Access Control) - a state-changing request that is not verified as coming from the legitimate user
- **Score:** CVSS entered into the NVD calculator using the endpoint's real impact (funds movement) - not a default guess
- **Contextualise:** in a banking system this enables unauthorised fund transfers via a forged request; in a different domain the same gap may be lower-impact
- **Document:** title + severity + evidence (the ZAP alert) + property violated (Integrity, Authenticity) + SRS mapping (APP-01) + remediation (implement and validate anti-CSRF tokens)

Activity: Interpret the Nmap Output

PART 1 OF 2 - NO ACTIVE SCANNING - PROVIDED OUTPUT ONLY

You are given a Nmap scan output for a system in your assigned domain. Do not run any scan yourself - interpret only.

Sample lines: 22/tcp open ssh | 80/tcp open http | 443/tcp open https | 3306/tcp open mysql

- 1. What does each open port suggest about the service running behind it?
- 2. Which of these services are potentially concerning, and why?

Activity: Interpret the Nmap Output

PART 2 OF 2 - SAME PROVIDED OUTPUT

- 3. Which SRS requirements are relevant here - NET-01, NET-02, or both? Why?
- 4. What further investigation would be needed before you could draft a finding from this alone?

Reminder: an open port is a fact, not a finding. A finding needs classification, scoring, context, and documentation - the pipeline from slide 15.

Small Lab: ZAP Passive Scan

PART 1 OF 2 - PASSIVE SCAN OF A PROVIDED DEMO APP ONLY

Run (or review the output of) a ZAP PASSIVE scan against the provided demo application. No active scan, no exploitation, no other target.

- 1. Review the automated findings ZAP produces.
- 2. Classify the top five findings by OWASP category (S6).

Small Lab: ZAP Passive Scan

PART 2 OF 2 - SCORE AND DOCUMENT

- 3. Assign a provisional CVSS score to the top three findings using the online NVD calculator (S8).
- 4. Draft the top finding in full professional format: title, severity, evidence, property violated, SRS mapping, remediation recommendation.

This finding format is the one you will reuse for every finding in Part B, and again in Session 12.

Try It: Blind Spot Probe



Open: `NB5004CEM_S9_ScanningTools_Demo_BlindSpotProbe.html` (double-click, works offline)

Try: probe each simulated finding - a Nmap port, a ZAP alert, a Burp-style request - and predict whether automated scanning alone could confirm it is exploitable, before revealing the answer.

Proves: automated tools are excellent at pattern-matching and completely blind to intent and business context - the exact distinction from slide 13, made personal by getting one wrong yourself.

Session Recap - Five Anchors



Anchor	This session
Five properties	Named through findings: Confidentiality/Integrity/Availability via ZAP categories, Authenticity/Accountability via the BOLA worked example
Five layers	Application and Network - the two layers this session's tools evaluate
STRIDE -> property	Intentionally light - attack surface (S2) referenced via Nmap; no new threat modelling today
Domain-assignment moment	Folded into the pipeline's Contextualise step and the Lab's finding, not a separate beat
Coursework hook	Dynamic evidence for Part B - B3 (network/platform) and B4 (application security); NET-01, NET-02, APP-01

Next session (S10): static and configuration analysis - the complement to today's dynamic tools, not a repeat of them.

Questions & Discussion



Evidence gathered today feeds directly into your Part B draft.



Disclaimer & Copyrights



The information presented in this presentation is intended for general informational purposes only. It is not meant to be comprehensive or to constitute professional advice. Any reliance you place on such information is strictly at your own risk. While I strive to keep the information accurate and up-to-date, I do make no representations or warranties of any kind, express or implied, about the completeness, accuracy, reliability, suitability, or availability concerning the content within this presentation.

This presentation may include references or links to third-party websites or content. I do not endorse the views expressed or the information provided on such external sites. I am not responsible for the content of any linked site or any link contained in a linked site.

Any action you take upon the information presented in this presentation is strictly at your own discretion. I will not be liable for any losses or damages in connection with the use of this information.

This disclaimer is subject to change without notice.

@ Images and artworks used in this presentation are used for general informational purposes only. It may contain copyrighted material, the use of which may not have been specifically authorised by the copyright owner. This material is available in an effort to explain issues relevant to the topic. This should constitute a 'fair use' of any such copyrighted material.

Last modified: 10 Jul 2026